

Nmap and Network Scanning

A COMPREHENSIVE GUIDE TO CYBERSECURITY
RECONNAISSANCE

Cybersecurity Course Material • Technical Deep Dive

Module 1: Introduction to Nmap and Network Fundamentals

1.1 What is Nmap?

Network Mapper (Nmap) is an open-source utility for network discovery and security auditing. It is widely considered the industry standard for network mapping, utilized by systems administrators for network inventory, managing service upgrade schedules, and monitoring host or service uptime. In the context of cybersecurity, it is an essential tool for both Red Team (offensive) and Blue Team (defensive) operations.

1.2 Core Applications of Nmap

Nmap is used to discover hosts on a network, identifying active systems. It performs service discovery by probing ports to determine what applications are running (and their versions). It also performs operating system detection by analyzing packet responses against a database of known fingerprints. For security professionals, it is used to identify vulnerabilities, map network topology, and verify firewall rules.

1.3 Nmap and the OSI Model

Nmap interacts primarily with the Data Link (Layer 2), Network (Layer 3), and Transport (Layer 4) layers of the Open Systems Interconnection (OSI) model. - ****Layer 2 (Data Link):**** On local networks, Nmap utilizes ARP (Address Resolution Protocol) requests to identify active hosts. This is highly efficient and bypasses IP-level firewalls. - ****Layer 3 (Network):**** Nmap uses ICMP (Internet Control Message Protocol) for host discovery (pings) and analyzes IP headers for OS fingerprinting (e.g., TTL values and fragmentation handling). - ****Layer 4 (Transport):**** This is where most scanning occurs. Nmap interacts with TCP and UDP to probe ports. By manipulating TCP flags (SYN, ACK, FIN, etc.), Nmap explores how a target's transport layer responds to determine port status.

Module 2: Mechanics of TCP Scanning

2.1 The TCP Three-Way Handshake

To understand Nmap, one must understand the standard TCP connection process: 1. ****SYN:**** The client sends a Synchronize packet to the server. 2. ****SYN-ACK:**** If the port is open, the server responds with a Synchronize-Acknowledgment. 3. ****ACK:**** The client sends an Acknowledgment, establishing the connection.

2.2 TCP Connect Scan (-sT)

The TCP Connect scan is the default scan type when a user does not have raw packet privileges (like root or sudo). It performs the full three-way handshake. If the connection is successful, Nmap knows the port is open. After the handshake, Nmap gracefully closes the connection with a RST or FIN packet. While reliable, it is easily logged by the target system because a full connection was established.

2.3 TCP SYN Stealth Scan (-sS)

Often called 'half-open' scanning, the SYN scan is the most popular Nmap technique. It works as follows: 1. Nmap sends a ****SYN**** packet. 2. If the port is open, the target sends a ****SYN-ACK****. 3. Nmap immediately sends a ****RST**** (Reset) packet to tear down the connection before it is fully established. This 'stealth' approach avoids the final ACK, meaning the application layer often never sees the connection attempt, preventing it from appearing in many application logs.

```
$ nmap -sS -T4 192.168.1.1
```

2.4 Response Interpretation

- ****SYN-ACK received:**** Port is Open. - ****RST received:**** Port is Closed. - ****No response / ICMP Unreachable:**** Port is Filtered (blocked by a firewall).

Module 3: UDP Scans and OS Detection

3.1 Understanding UDP Scans (-sU)

Unlike TCP, the User Datagram Protocol (UDP) is connectionless. There is no three-way handshake. When Nmap sends a UDP packet to a port: 1. If a UDP response is received (which is rare), the port is **Open**. 2. If an 'ICMP Port Unreachable' error (Type 3, Code 3) is received, the port is **Closed**. 3. If no response occurs, the port is categorized as **Open|Filtered**.

```
$ nmap -sU -p 53,67,68 192.168.1.1
```

3.2 Why are UDP Scans Slower?

UDP scans are significantly slower for two reasons: - **No response:** When a port is actually open or silently filtered, Nmap must wait for a timeout because there's no definite way to know if the packet reached its destination. - **Rate limiting:** Most operating systems (especially Linux) limit the rate at which they send ICMP error messages (e.g., one per second). Nmap must respect this limit to avoid missing data, making a full 65,535 port scan take hours or even days.

```
$ nmap -sU -p 53,67,68 192.168.1.1
```

3.3 OS Detection (-O)

Nmap's OS detection is a sophisticated fingerprinting process. It sends a series of TCP and UDP packets to open and closed ports and evaluates the responses. It checks: - **TCP Options:** Sequence numbers, window size, and MSS. - **ICMP Responses:** Handling of address mask requests. - **IP ID Generation:** Whether IDs are incremental, random, or static. Nmap compares these results against a massive database of over 5,000 known fingerprints to identify the exact OS version.

```
$ nmap -O 192.168.1.1
```

Module 4: Nmap Scripting Engine and Port Status

4.1 The Nmap Scripting Engine (NSE)

NSE is one of Nmap's most powerful features. It allows users to write and share scripts to automate networking tasks. Scripts are written in the Lua programming language. Common categories include:

- **Discovery:** Identifying network resources (e.g., WHOIS lookups).
- **Vulnerability:** Scanning for known vulnerabilities (e.g., heartbleed, smb-vuln).
- **Exploitation:** Executing basic exploits (though limited compared to Metasploit).
- **Brute:** Brute-forcing application credentials.

4.2 Understanding Port Status Results

Nmap maps each port to one of six states:

- **Open:** The application is actively accepting connections.
- **Closed:** No application is listening, but the port is reachable (it responded with a RST).
- **Filtered:** Nmap cannot determine state because a firewall or packet filter is dropping the packets. No response was received.
- **Unfiltered:** Only occurs in ACK scans, meaning the port is reachable but its open/closed status is unknown.
- **Open|Filtered:** Returned when Nmap receives no response to a UDP or IP protocol scan (unable to distinguish between open and filtered).
- **Closed|Filtered:** Used when Nmap is uncertain if a port is closed or filtered (e.g., during IP ID Idle scans).

Module 5: Firewall Evasion and Advanced Scanning

5.1 Firewall Evasion Techniques

Intrusion Detection Systems (IDS) often block simple Nmap scans. Advanced techniques include:

- **Fragmentation (-f):** Splitting the TCP header across multiple small IP packets. Modern firewalls (like stateful ones) often reassemble them, making this less effective than it was in the past, but it can still bypass older packet filters.
- **Decoys (-D):** Nmap allows the user to specify decoys. The target's logs will show multiple IP addresses scanning them simultaneously, one being the real attacker and the rest being fake decoys. This makes it challenging to identify the true source.
- **Timing and Performance:** Nmap offers six timing templates (T0-T5). T0 (Paranoid) and T1 (Sneaky) are specifically designed to evade detection by sending packets very slowly (e.g., minutes apart). T5 is optimized for extremely fast, high-performance scanning on robust local networks.

5.2 The Xmas Scan (-sX)

The Xmas scan is named because it 'lights up a packet like a Christmas tree' by setting the FIN, PSH, and URG flags simultaneously. According to RFC 793, if a closed port receives this packet, it must respond with a RST. If the port is open, the packet should simply be dropped (no response). This is a great way to detect Unix/Linux systems that follow RFC 793, but it works poorly on Windows systems, which may respond with a RST whether the port is open or closed.

```
$ nmap -sX 192.168.1.1
```

5.3 Use of ICMP in Discovery

ICMP is Nmap's bread and butter for discovery. Before scanning 65,535 ports, Nmap tries to verify if a host is 'up' by sending ICMP Echo requests (pings). If ICMP is blocked, Nmap can still use TCP SYN/ACK ping to see if a specific port responds, effectively using transport layer interaction to infer host status on the network layer.

Module 6: Cybersecurity Strategy and Nmap

6.1 Active vs Passive Reconnaissance

Nmap is an **active** reconnaissance tool because it directly interacts with the target. This carries a risk of detection. Passive reconnaissance involves gathering data from third-party sources (e.g., Shodan) without ever sending a packet to the target. Active recon (Nmap) provides more precise and up-to-date information but should be used carefully in red team engagements.

6.2 Nmap in the Attack Lifecycle

Nmap's place is primarily in the **Reconnaissance** and **Scanning** phases of the Cyber Kill Chain. Once a target's IP is identified, Nmap maps the services. This then informs the **Exploitation** phase. For example, if Nmap identifies an outdated version of an SSH server through service detection (-sV), the attacker can look for a corresponding exploit in a database like Exploit-DB.

6.3 Common Flags Summary Table

- **-sS:** Stealth SYN Scan - **-sV:** Service/Version Detection - **-sC:** Use Default Scripts - **-O:** OS Detection - **-p-:** Scan all ports (1 to 65,535) - **-A:** Aggressive mode (includes OS, Service, Scripts, and Traceroute) - **-T4:** Fast timing (good for general use)

```
$ nmap -T4 10.0.0.1
```